WEBSITE SECURITY PLAN

Keeping the site safe once it's live.

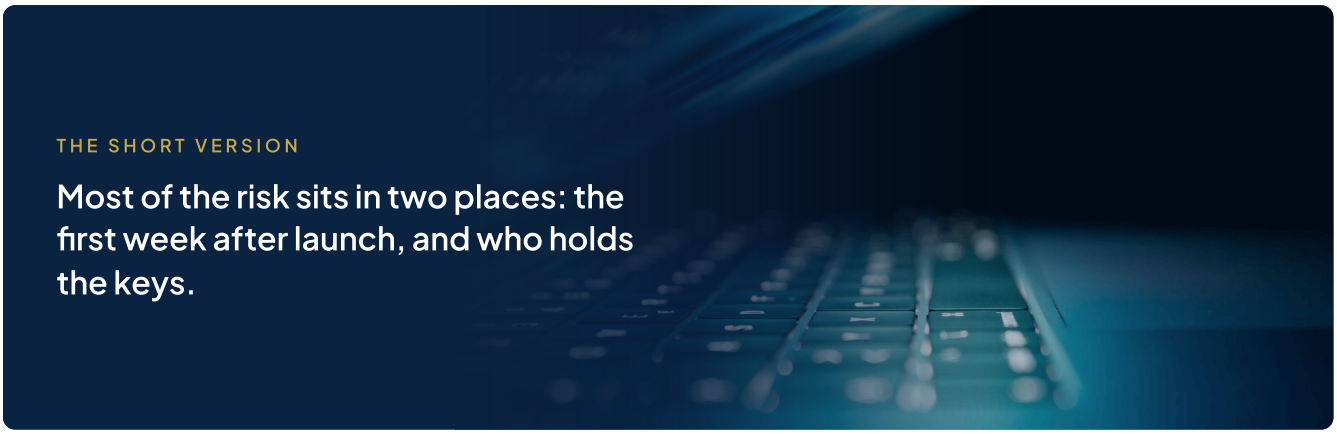
A step-by-step plan for the weeks after the new NeuroAIQ website goes live — what we lock down on day one, what we keep an eye on, and what happens if something goes wrong. It builds on what's already in place rather than starting over.

PREPARED FOR
NeuroAIQ Pty Ltd

PREPARED BY
Team B58
La Trobe University

DATE
28 September 2026

VERSION
1.0 — for review



THE SHORT VERSION

Most of the risk sits in two places: the first week after launch, and who holds the keys.

1 Why this matters for NeuroAIQ

NeuroAIQ sells evidence and trust to senior leaders. A defaced homepage or a fake email from an @neuroaiq.com.au address would cost more than downtime — **it would undercut the credibility the new site is being built to earn.**

YOUR BUYERS

Your buyers are the ones targeted

CEOs, founders and heads of transformation are exactly the people targeted by fake invoices and lookalike emails. If someone can send a convincing email as NeuroAIQ, **your buyers are the ones who'll receive it.**

THE CONTACT FORM

Every enquiry is personal data

Names, work emails, phone numbers — and what people say about their organisation's AI problems. Looking after that properly is **a legal expectation and a sales one**, because larger buyers will ask.

THE RELAUNCH

Launch week is the riskiest week

A new site means new code, changed DNS and fresh admin accounts. Most of the easy mistakes happen in the first few days, **which is why this plan front-loads them.**

2 Where things stand today

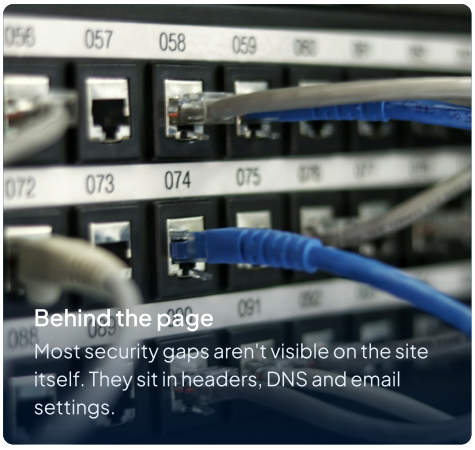
We checked the live site on 28 September 2026 using public information only — the same response headers and DNS records any browser or mail server sees when it connects. **No testing was run against the site itself.**

The good news first: the basics are there. The site runs on HTTPS and the domain already restricts who can issue certificates for it — a step many small business sites miss.

The gaps are mostly **settings, not rebuilds** — configuration changes that can be made at launch, at little or no cost.

SET UP TODAY

WordPress, served by LiteSpeed. The domain's nameservers are Hostinger's. Email runs through **Microsoft 365**, and the domain also authorises **HubSpot** to send on its behalf.



Behind the page
Most security gaps aren't visible on the site itself. They sit in headers, DNS and email settings.

CHECK	WHAT WE FOUND	STATUS
HTTPS	Loads securely, and plain http:// redirects to https://	IN PLACE
Certificate restriction (CAA)	Only named authorities can issue certificates	IN PLACE
Email sender list (SPF)	Covers Microsoft 365 and HubSpot, on soft fail	IN PLACE
Email spoofing (DMARC)	Monitoring only — **fake emails aren't rejected**	FIX FIRST
Force HTTPS (HSTS)	Not set — browsers aren't told to insist on HTTPS	FIX AT LAUNCH
Content Security Policy	Effectively absent — nothing limits what can load	FIX AT LAUNCH
Clickjacking protection	Not set — other sites can frame the page	FIX AT LAUNCH
Other security headers	Content-type and referrer headers not set	FIX AT LAUNCH
Version disclosure	Server names its PHP version; page names its plugins	IMPROVE
DNSSEC	Not enabled on the domain	IMPROVE
Firewall in front of the site	No web application firewall or CDN detected	IMPROVE

THE ONE TO ACT ON FIRST

The DMARC setting. It's the only finding that affects NeuroAIQ even while the website is working perfectly. At `p=none`, receiving mail servers are told not to reject email that fails the domain's checks — so whether a fake NeuroAIQ email gets blocked is left to each recipient's own filters. The reports it generates currently go to **info@neuroaiq.com.au** as raw data files, where they're unlikely to be read.

Checks: HTTPS response headers, public DNS (SPF, DMARC, MX, NS, CAA, DS records).

3 The one decision that changes this plan

The current site runs on WordPress. The rebuilt site doesn't have a confirmed home yet, and **that choice changes more of this plan than anything else in it.**

	STAYS ON WORDPRESS	MOVES TO STATIC HOSTING
What can be attacked	The login page, plugins, themes, the database and PHP	Only the files being served — no login, no database
Ongoing patching	Weekly — core, plugins and themes all need updates	Rare — only when the site itself is rebuilt
Who can change content	Anyone with a login, from anywhere	Changes go through a controlled deployment
Editing without a developer	Yes, through the WordPress dashboard	Not directly — needs a developer or a headless CMS
Running cost	Existing hosting plan	Free to low, on Cloudflare Pages or similar

OUR RECOMMENDATION

If the choice is still open, **move to static hosting behind Cloudflare.** It removes the biggest attack surface a small business website has — the login page and its plugins — and it costs less to run. The trade-off is editing: if NeuroAIQ needs to publish or change pages without a developer, WordPress stays, and Step 6 covers how to harden it properly. Everything else in this plan applies either way.

4 The plan at a glance

Nine steps across five stretches of time, overlapping where the work does. The front-loading is deliberate: most of the work happens before and just after launch, then it settles into a light routine.



WEEK BEFORE	LAUNCH DAY	FIRST WEEK	WEEKS 1–8	ONGOING
Prepare	**Switch over**	**Lock it down**	**Tighten & back up**	**Watch & respond**
Step 1	Step 2	Steps 3, 4, 5	Steps 4, 6, 7	Steps 8, 9
Access audit	DNS switch	Security headers	DMARC to reject	Uptime alerts
MFA everywhere	HTTPS on every page	Cloudflare in front	WordPress hardening	Monthly scans
Full backup	Form test	DMARC reporting	Daily backups	Access reviews
Rollback written	Old URLs redirect	Form protection	First restore test	Incident runbook

Effort drops sharply after week eight — **about an hour a month** once it's all in place.

Step numbers refer to the sections that follow.

01

THE WEEK BEFORE LAUNCH

Know who holds the keys

Before anything moves, we need a clear picture of every account that can change the site, the domain or the email — and we need each one protected.

- [ ] **List every admin account** across the domain registrar, hosting, DNS, WordPress, Microsoft 365 and HubSpot — then remove anyone who no longer needs access.
- [ ] **Turn on multi-factor authentication** for every one of those accounts. This single step stops the large majority of account takeovers.
- [ ] **Move shared passwords into a password manager.** No passwords in emails, chat messages or documents — including this project's.
- [ ] **Take a full backup of the current site** and keep a copy somewhere other than the hosting account.
- [ ] **Lower the DNS time-to-live** to five minutes, 48 hours before launch, so the switch is quick and easy to reverse.
- [ ] **Write down the rollback** — exactly how to point the domain back to the old site if launch goes wrong, and who's allowed to call it.

02

LAUNCH DAY

Switch over, then prove it works

Launch isn't finished when the new site appears. It's finished when we've checked it from the outside.

- [ ] **Switch DNS in a quiet window** — early on a Tuesday or Wednesday morning, Melbourne time, so any problem hits the fewest visitors.
- [ ] **Confirm HTTPS on every page**, with and without `www`, and that both land on the same address.
- [ ] **Send a real test enquiry** through the contact form and confirm it reaches the right inbox.
- [ ] **Run two free external checks** — SSL Labs and securityheaders.com. We're aiming for an A on both.
- [ ] **Check every old address redirects** to its new page. This protects search rankings as much as security.
- [ ] **Leave the old site's backup untouched** for at least 30 days.

WHY A QUIET WINDOW

DNS changes don't reach everyone at once

Even with the time-to-live lowered, some networks hold on to the old address for a while, so for a short period visitors can see either site. Launching when traffic is lowest means fewer people land in that gap — and **it gives us room to roll back** before most of Australia is at work.

PASS MARK

A / A

SSL Labs and securityheaders.com, both run on launch day and saved as a record.

03

THE FIRST WEEK

Lock the front door

Two changes close most of the gaps in section 2: a set of security headers, and Cloudflare in front of the site.

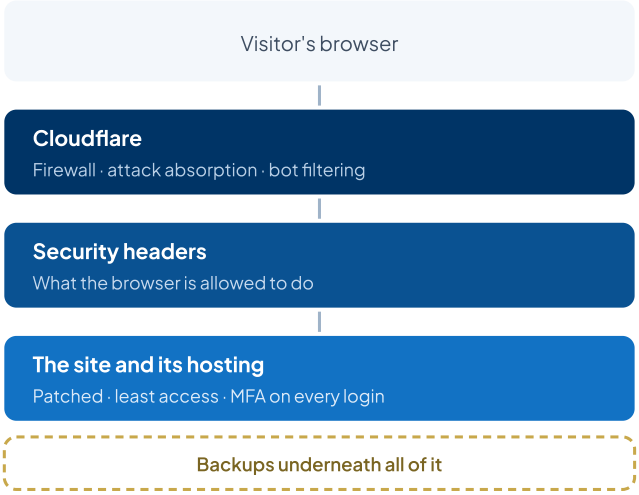
Security headers are short instructions the site sends to every visitor's browser, telling it how to behave. They cost nothing, they're set once, and they're what the securityheaders.com grade measures. The Content Security Policy takes the most care — **it has to list every service the site legitimately uses**, such as HubSpot and web fonts, or those stop working.

HEADER	WHAT IT DOES, IN ONE LINE
`Strict-Transport-Security`	Tells browsers to only ever use a secure connection for this site
`Content-Security-Policy`	Lists the only places the page may load scripts and styles from — so injected code is far harder to run
`frame-ancestors`	Stops other sites loading NeuroAIQ inside theirs to trick visitors into clicking
`X-Content-Type-Options`	Stops browsers guessing what a file is — a common way to sneak code in
`Referrer-Policy`	Limits what's passed on about a visitor when they click through to another site
`Permissions-Policy`	Switches off camera, microphone and location, which the site never needs

We'll also stop the server announcing its PHP version and the page naming its plugins — there's no reason to tell anyone what to look up.

Cloudflare's free plan sits between visitors and the website. It absorbs attacks designed to knock the site offline, filters out automated traffic, applies basic firewall rules and hides the hosting server's real address.

Setting it up means moving the domain's DNS to Cloudflare. Once it's there, **DNSSEC is a single switch** — closing another of the gaps from section 2.

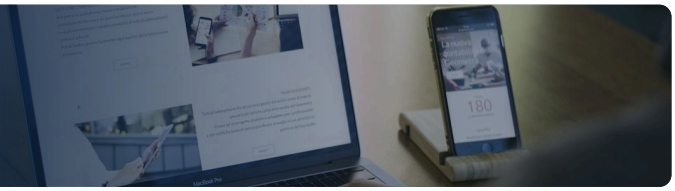


WHY LAYERS

No single measure is enough on its own. Each layer catches what the one before it misses — **so a single mistake doesn't become an incident.**

EVERY PAGE, EVERY DEVICE

Headers travel with every page the site sends — phone, tablet or desktop.

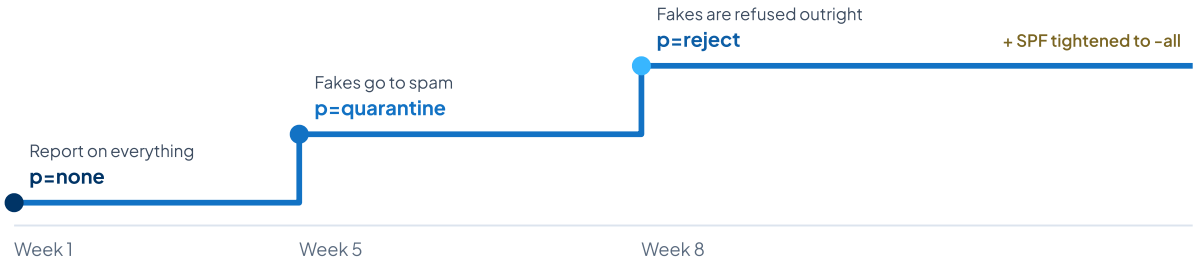


04

WEEKS ONE TO EIGHT

Stop anyone pretending to be NeuroAIQ

This is the fix-first item from section 2. It's done in stages, because doing it all at once risks blocking NeuroAIQ's own emails.



WEEK 1

Point the reports somewhere useful

Keep `p=none`, but send reports to a reporting tool that turns them into a readable summary — Cloudflare offers DMARC reporting once DNS moves there.

WEEKS 2 TO 4

Confirm every real sender passes

Microsoft 365, HubSpot and the website's contact form all need to pass before we tighten anything. **Third-party senders like HubSpot are the ones most often missed.**

WEEKS 5 TO 8

Quarantine, then reject

Move to `p=quarantine`, watch for a few weeks, then `p=reject`. Once that's stable, SPF moves from `~all` to `-all`.

05

THE FIRST WEEK

Look after every enquiry

The contact form is the one place the site collects personal information, so it gets its own step.

- [ ] **Add Cloudflare Turnstile** — free spam protection with no puzzles for real visitors.
- [ ] **Check every field on the server**, not just in the browser, where it's easy to bypass.
- [ ] **Only ask for what's used.** If phone number isn't needed to respond, make it optional.
- [ ] **Don't store enquiries on the web server.** Send them to Microsoft 365 or HubSpot and nowhere else.

PRIVACY

The **Privacy Act 1988** covers most businesses turning over more than $3 million a year, and some smaller ones depending on what they do. Whether or not it formally applies to NeuroAIQ, we recommend **handling enquiry data as though it does** — with a published privacy policy covering what's collected, why, where it's kept and how to ask for it to be deleted. It's what larger buyers expect to see.

DMARC dates count from launch day. Timings can stretch if any legitimate sender needs fixing.

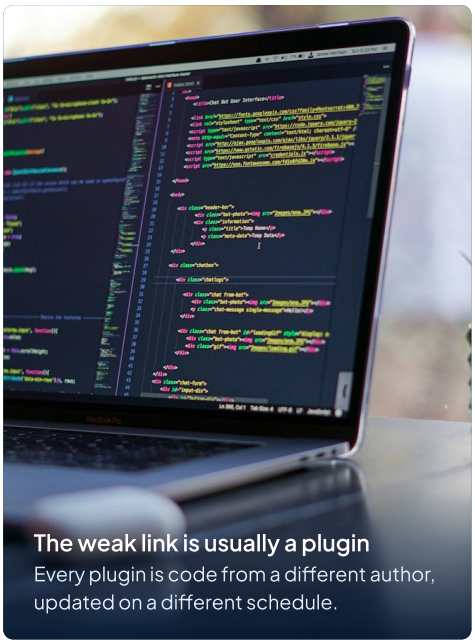
06

ONLY IF THE SITE STAYS ON WORDPRESS

Harden WordPress properly

WordPress isn't insecure on its own. Most compromised WordPress sites got that way through an outdated plugin or a weak admin login — so that's where this step goes.

- [ ] **Remove one of the two SEO plugins.** Both Yoast SEO and All in One SEO are active on the current site and both write to the page — one needs to go, for security and for search.
- [ ] **Delete every plugin and theme that isn't used.** A deactivated plugin can sometimes still be exploited if its files are there.
- [ ] **Turn on automatic updates** for WordPress itself and every remaining plugin.
- [ ] **Protect the login** — limit failed attempts, require MFA for every admin, and restrict who can reach the login page.
- [ ] **Switch off XML-RPC** unless something specifically needs it. It's a common route for password-guessing.
- [ ] **One person, one account**, each with the lowest role that does the job. No shared admin login.
- [ ] **Add a security plugin** such as Wordfence for a firewall and malware scanning.



The weak link is usually a plugin
Every plugin is code from a different author, updated on a different schedule.

07

WEEKS ONE TO EIGHT, THEN ONGOING

Backups you can actually restore

A backup that's never been restored is a guess. This step is as much about testing as it is about copying.

3
copies of the site
the live one and two backups

2
different places
so one failure can't take both

1
off the hosting account
entirely, in case that's what's lost

WHAT WE SET UP	TARGET
Automatic backups	Daily, kept for 30 days
How fast the site comes back	**Within four hours** of deciding to restore
How much work could be lost	**No more than one day's** changes
Restore test	Every quarter — restored to a test address and checked

For a static site, the code repository is itself a backup — but the contact-form setup and DNS still need recording.

08

ONGOING

Know before your clients do

The aim is simple: if something breaks, NeuroAIQ hears about it from an alert, not from a prospect.

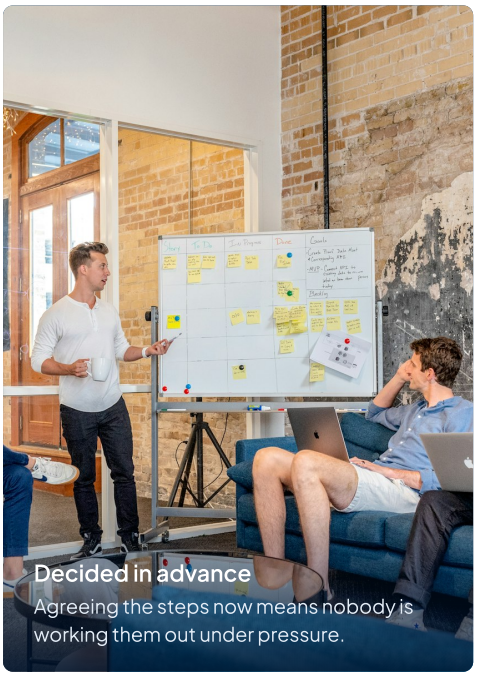
UPTIME **Check every five minutes**	A free monitor such as UptimeRobot checks the site around the clock and **sends an alert the moment it stops responding.**
CERTIFICATES **Never let HTTPS lapse**	Certificates renew automatically, but renewals fail quietly. An expiry alert catches it weeks ahead instead of on the day browsers start warning visitors.
GOOGLE **Let Google tell us too**	Search Console flags hacked content and malware it finds on the site — and it's already part of the SEO plan, so **this one costs nothing extra.**
MONTHLY **Re-run the launch checks**	SSL Labs and securityheaders.com again. If either grade drops, something changed that shouldn't have.

09

IF SOMETHING GOES WRONG

Five moves, in this order

When something goes wrong, people lose time working out what to do. This is decided now, so nobody has to think about it under pressure.



Decided in advance
Agreeing the steps now means nobody is working them out under pressure.

1 · CONTAIN
Take the site offline or to a holding page. Change passwords.

2 · ASSESS
What happened, what data was involved, and since when.

3 · RESTORE
From the last backup known to be clean — not always the latest.

4 · NOTIFY
If personal data was involved, work out who must be told.

5 · LEARN
Write up what happened, fix the cause, update this plan.

If NeuroAIQ is covered by the Privacy Act and a breach is likely to cause serious harm, it must be reported to the OAIC and the people affected under the **Notifiable Data Breaches** scheme. Cyber incidents can also be reported to the Australian Cyber Security Centre through **ReportCyber** at cyber.gov.au.

We recommend a one-page version of this runbook, with names and phone numbers, as part of the handover.

5 The routine, once it's all in place

After week eight it comes down to a short list at a steady rhythm — **about an hour a month.**

WEEKLY
Five minutes
Glance at uptime alerts. On WordPress, confirm updates ran.

MONTHLY
Half an hour
Re-run both scans. Check backups ran. Read the DMARC summary.

QUARTERLY
An hour
Test a restore. Review who has access, and remove anyone who shouldn't.

YEARLY
Half a day
Independent security review. Rotate key passwords. Revisit this plan.

6 Who does what

Team B58 finishes on **9 October 2026**. Everything above needs a named owner after that.

TASK	NEUROAIQ	TEAM B58 TO 9 OCT	WEB SUPPORT AFTER HANDOVER	HOSTING PROVIDER
Steps 1–5 — setup and launch	Approves	**Does**	—	Supports
Admin access and MFA	**Owns**	Sets up	Reviews	—
DMARC rollout to reject	Approves	Starts	**Finishes**	—
Updates and patching	—	Sets up	**Does**	Server level
Backups and restore tests	—	Sets up	**Does**	Keeps copies
Monitoring alerts	**Receives**	Sets up	**Acts**	—
Incident decisions	**Decides**	—	Advises	Assists

7 What it costs

Most of this is free. The ongoing costs are a password manager and whoever takes on the routine.

ITEM	COST	COVERS
Cloudflare, free plan	Free	DNS, firewall, DNSSEC, Turnstile, DMARC reporting
Uptime monitoring	Free	Five-minute checks with email alerts
SSL Labs, securityheaders.com	Free	Launch and monthly checks
Wordfence (WordPress only)	Free tier	Firewall and malware scanning
Password manager	Low, per person	Shared logins, stored safely — e.g. Bitwarden, 1Password
Ongoing web support	To be agreed	The routine in section 5, after 9 October

Costs are indicative and based on current free tiers, which providers can change.

8 How this lines up with the Essential Eight

The **Essential Eight** is the baseline the Australian Cyber Security Centre recommends every organisation start with. Four of the eight apply directly to a website, and this plan covers each of them.

ESSENTIAL EIGHT

Multi-factor authentication

Step 1, on every admin account.

ESSENTIAL EIGHT

Restrict admin privileges

Steps 1 and 6 — one person, one account, lowest role.

ESSENTIAL EIGHT

Patch applications

Step 6 and the routine — automatic updates.

ESSENTIAL EIGHT

Regular backups

Step 7 — daily, off-site, and tested.

The remaining four cover staff computers, office software and the servers themselves — the last of which the hosting provider looks after.

9 What we need from you

These are genuine gaps rather than assumptions we've chosen not to make. **Questions 1 and 2 shape the rest of the plan**, so they're the ones we'd most like answered first.

#	QUESTION	WHY IT MATTERS
1	Where will the rebuilt site be hosted — and will it stay on WordPress?	Decides whether Step 6 applies
2	Is launch planned before or after 9 October — and who looks after security once Team B58 finishes?	Sets who does Steps 1–5, and who owns the routine
3	Who currently holds admin access to the registrar, hosting, Microsoft 365 and HubSpot?	Needed for Step 1
4	Does NeuroAIQ need to edit site content without a developer?	Drives the platform decision
5	How are changes from the three teams coordinated before they reach the live site?	Uncontrolled changes are a risk
6	Should contact-form enquiries go to HubSpot, Microsoft 365, or both?	Needed for Step 5

NEXT STEP

With answers to questions 1 and 2, this becomes a dated checklist for launch week.

NeuroAIQ
The Neuroscience of AI Adoption